

Clase 188 — Threat hunting: metodología

Parte: 8 — Blue Team, detección y SOC · Fuente: *The Practice of Network Security Monitoring* — Richard Bejtlich 🕒 Duración estimada: 110 min · Nivel: Avanzado

Objetivo

Aprender a cazar amenazas de forma proactiva: buscar en la telemetría lo que ninguna alerta disparó, partiendo de hipótesis fundadas en ATT&CK y en la inteligencia de amenazas. Aplicarás un ciclo repetible (hipótesis → investigación → hallazgo → nueva detección) y evitarás el "hunting" improvisado que no deja aprendizaje.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

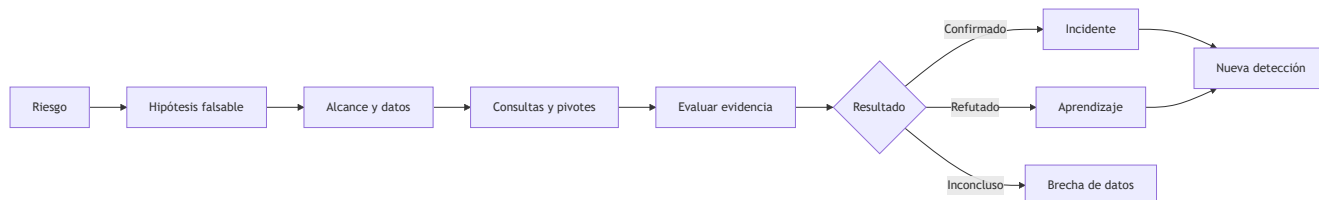
- 1. **Formular** hipótesis de caza accionables y medibles.
- 2. **Aplicar** el ciclo de hunting y el modelo de madurez de caza (HMM).
- 3. **Usar** el marco TaHiTI/PEAK para estructurar una cacería.
- 4. **Convertir** hallazgos de hunting en detecciones automatizadas.
- 5. **Documentar** una cacería de forma reproducible.

Temas

#	Tema	Por qué importa
1	Qué es (y qué no es) el hunting	Diferenciar de monitoreo de alertas
2	Hunting basado en hipótesis	Da foco y evita cazar sin rumbo
3	Modelo de madurez de caza (HMM)	Sitúa tu capacidad y próximos pasos
4	Marcos TaHiTI y PEAK	Estructura repetible de una cacería
5	Fuentes de hipótesis (ATT&CK, intel, anomalías)	De dónde salen las buenas preguntas
6	Baselining y análisis de outliers	Encontrar lo anómalo sin firma
7	De hallazgo a detección	Capitalizar la caza
8	Documentación y métricas de caza	Aprendizaje acumulativo

Explicación en profundidad

Threat hunting es una investigación proactiva y acotada que parte de una hipótesis falsable; no consiste en recorrer dashboards esperando algo extraño. La hipótesis nombra actor o mecanismo, objeto, acción, contexto y evidencia esperada. El alcance fija entidades, periodo, fuentes y criterios de salida para evitar una búsqueda infinita.



Una anomalía no equivale a malicia: puede revelar administración legítima o mala calidad de datos. Se compara con una línea base pertinente y se buscan pruebas que también puedan refutar la intuición. Confirmado, refutado e inconcluso son resultados útiles si conservan consultas, versiones y límites. El producto puede ser incidente, regla, mejora de logging o control preventivo.

Formular una hipótesis investigable

«Buscar actividad rara» no indica qué observar ni cuándo terminar. En cambio: «una cuenta de backup, que no debería iniciar sesiones interactivas, pudo usar RDP durante la madrugada; deberían existir autenticación remota y procesos ajenos al agente de backup» define entidad, desviación, periodo y evidencia. Antes de consultar se verifica que inventario y logs distinguan esas propiedades.

La hipótesis incluye alternativas benignas. Mantenimiento aprobado podría explicar la sesión; una cuenta mal clasificada podría invalidar la línea base. Buscar activamente esas explicaciones reduce sesgo de confirmación. El alcance fija hosts, identidades, días y fuentes, además de un límite de tiempo para que el hunt sea gestionable.

Ejecutar y documentar pivotes

Primero se mide frecuencia y distribución, luego se pivota por origen, destino, proceso, privilegio y red. Cada consulta responde una pregunta escrita. Si un resultado cambia la hipótesis, se registra; no se reescribe la historia como si siempre se hubiera sabido. Las consultas conservan rango, zona horaria, versión y campos usados.

Confirmado inicia respuesta y alcance. Refutado mejora conocimiento normal. Inconcluso identifica exactamente el dato ausente; no se presenta como «no hay amenaza». El diagrama termina en detección porque una conducta repetible puede convertirse en analítica, pero algunos hallazgos se corrigen mejor con política, segmentación o logging.

Línea base y rareza

Una línea base no es un promedio universal. Se segmenta por rol de activo, tipo de cuenta, horario y estacionalidad. Un controlador de dominio y una estación de diseño no comparten normalidad. Los outliers ayudan a ordenar investigación, pero popularidad tampoco garantiza legitimidad: una técnica extendida puede volverse común. El hunter combina estadística, conocimiento del sistema y evidencia causal.

Modelos de madurez y marcos: mapas, no recetas

El Hunting Maturity Model describe una progresión desde dependencia de procedimientos automatizados hacia hunts guiados por datos y capacidad de crear nuevas analíticas. Sirve para conversar sobre capacidad, no para asignar prestigio a un equipo. Una organización puede tener buenos hunters y datos insuficientes; el siguiente paso sería mejorar telemetría, no ejecutar hunts más sofisticados en el vacío.

TaHiTI estructura el proceso desde propósito e hipótesis hasta investigación y resultados. PEAK, publicado por Splunk, diferencia enfoques basados en hipótesis, baseline y exploración asistida por modelo, y enfatiza operación repetible. Se elige el marco que ayude a responder la pregunta; no se mezclan siglas para aparentar metodología. En todos los casos deben existir alcance, evidencia, decisión y transferencia de aprendizaje.

De dónde nacen hipótesis útiles

ATT&CK aporta procedimientos; inteligencia aporta campañas y contexto; incidentes y purple team revelan brechas; cambios de arquitectura crean nuevas preguntas; anomalías sugieren fenómenos que todavía deben explicarse. Una hipótesis no necesita nombrar un actor. «Un token de sesión puede reutilizarse desde una ubicación nueva» puede ser más comprobable que «el grupo X está dentro».

Métricas de hunting

Contar hunts o queries incentiva actividad, no valor. Se observan hipótesis cerradas, hallazgos corroborados, brechas de datos corregidas, analíticas creadas y tiempo hasta operacionalización, junto con limitaciones. Un hunt refutado puede ser valioso si mejora baseline. La documentación permite que otro analista lo repita y evita investigar la misma pregunta desde cero.



Glosario

- **Hipótesis falsable:** afirmación que la evidencia puede refutar.
- **Baseline:** comportamiento normal para un contexto.
- **Pivote:** consulta que sigue una entidad relacionada.
- **Scope:** límites temporales, técnicos y organizativos.
- **Hallazgo:** observación sustentada que requiere acción.
- **Inconcluso:** evidencia insuficiente para decidir.
- **Paquete de hunt:** hipótesis, datos, consultas y resultados reproducibles.



Definiciones y características

- **Threat hunting:** búsqueda proactiva e iterativa de amenazas que evadieron los controles automáticos. Característica: parte de una hipótesis, no de una alerta.
- **Hipótesis de caza:** afirmación comprobable sobre actividad adversaria posible en el entorno. Característica: concreta, ligada a datos disponibles y a una técnica.
- **Hunting Maturity Model (HMM):** escala de HM0 (solo alertas) a HM4 (caza automatizada). Característica: mide la capacidad del equipo.
- **TaHiTI:** metodología de hunting dirigida por inteligencia de amenazas (Targeted Hunting integrating Threat Intelligence). Característica: enlaza intel con abuso concreto.
- **PEAK:** marco moderno (Prepare, Execute, Act with Knowledge) para cacerías de hipótesis, baseline y ML. Característica: estructura y documenta el proceso.
- **Baseline:** modelo de lo normal en el entorno. Característica: sin él, no se distingue lo anómalo.



Hunt completo — cuenta de backup con sesión interactiva

Hipótesis: una cuenta destinada a backup pudo iniciar una sesión interactiva en servidores fuera de mantenimiento. **Alternativas:** intervención aprobada, inventario incorrecto o servicio mal configurado.

Alcance: treinta días, servidores administrados y eventos de identidad/endpoint.

Primero se valida que el inventario identifica la cuenta y que la telemetría distingue sesión interactiva. Se mide frecuencia por tipo, origen y destino. Aparece un acceso desde un jump host durante una ventana aprobada: refuta esa observación como amenaza, pero revela que la documentación de la cuenta era incompleta. Otro acceso desde una estación común carece de cambio aprobado; se pivota a procesos y privilegios. La evidencia resulta inconclusa porque faltan procesos del destino durante ese intervalo.

El hunt no declara «sin compromiso». Produce dos salidas: corregir inventario y logging del segmento, además de una consulta candidata que alerta cuando una cuenta de servicio usa sesión interactiva desde origen no autorizado. Las consultas, rango y resultados se guardan para repetir después de mejorar datos.

✓ Criterio de dominio

Se evalúa si la hipótesis era falsable, si se buscaron explicaciones benignas, si cada pivote respondió una pregunta y si el resultado distingue confirmado, refutado e inconcluso. Encontrar muchos outliers sin cerrar razonamiento no constituye un hunt completo.

🧰 Herramientas y preparación

- Tu SIEM (Splunk/Elastic) con telemetría de endpoint y red de clases previas.
- **Jupyter Notebook** o un documento estructurado para registrar la cacería.
- **Atomic Red Team** para generar actividad de prueba que después "cazarás" (en laboratorio propio).
- El catálogo **ATT&CK** como fuente de hipótesis.

Toda ejecución de técnicas para practicar la caza se realiza en tu entorno aislado y autorizado.

🔬 Laboratorio guiado — Una cacería de principio a fin

1. **Prepara (PEAK).** Elige una técnica: T1053.005 (Scheduled Task/Job). Formula la hipótesis: "*un adversario ha creado tareas programadas para persistir en algún host*".
2. **Define datos y ámbito.** Identifica la telemetría (Sysmon Event ID 1/schtasks, Security 4698) y el rango temporal (últimos 7 días).
3. **Construye la baseline.** Lista las tareas programadas legítimas y sus creadores habituales para separar ruido de señal.
4. **Ejecuta la búsqueda.** En el SIEM, filtra creaciones de tareas y agrupa por host, usuario y binario invocado; ordena por rareza.
5. **Investiga outliers.** Para las tareas raras, pivota: ¿qué proceso las creó?, ¿hay conexión de red asociada?, ¿el binario está firmado?
6. **Genera actividad de control.** Con Atomic Red Team lanza una técnica de tarea programada y confirma que tu búsqueda la habría encontrado.
7. **Capitaliza.** Convierte la búsqueda en una regla Sigma/alerta para automatizar la detección a futuro.
8. **Documenta.** Registra hipótesis, consultas, hallazgos, falsos positivos y la detección creada.

🔧 Ejercicios

1. Redacta 3 hipótesis de caza a partir de técnicas ATT&CK distintas.
2. Sitúa a tu SOC en el HMM y define el paso para subir un nivel.
3. Construye una baseline de procesos que hacen conexiones salientes.

4. Diseña una cacería de "living off the land" (LOLBins) y sus consultas.
5. Convierte un hallazgo de caza en una regla Sigma.
6. Define 3 métricas de éxito de una cacería.

Reto verificable

Ejecuta una cacería completa documentada (hipótesis, datos, consultas, hallazgos y detección resultante) sobre una técnica ATT&CK a tu elección. **Criterio de aceptación:** la actividad de control que generas con Atomic Red Team aparece en tus resultados de caza, distinguible de la baseline, y entregas una detección nueva (Sigma o saved search) derivada del hallazgo.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Cazar" abriendo dashboards al azar	Falta hipótesis; empieza siempre por una pregunta comprobable
Todo parece sospechoso	No hay baseline; modela lo normal primero
Hallazgos que no se reutilizan	No capitalizas; convierte cada caza en detección o baseline
Cacerías irreproducibles	Sin documentación; registra consultas y decisiones
Nunca encuentras nada	Datos insuficientes o hipótesis inverosímil; ajusta telemetría o pregunta

Preguntas frecuentes

? ¿El hunting requiere herramientas caras? No. Requiere buena telemetría, hipótesis y método. Con un SIEM open source y Sysmon ya puedes cazar; la madurez viene del proceso, no del precio.

? ¿Cazar es buscar sin saber qué? Al contrario. Sin hipótesis no es caza, es navegación aleatoria. La hipótesis enfoca el esfuerzo y hace medible el resultado.

? ¿Cada cacería debe encontrar un atacante? No. Una cacería "sin hallazgo" es valiosa: valida controles, mejora baselines y suele revelar higiene o puntos ciegos que corregir.

Referencias verificables y alcance

- Bianco, D. *Hunting Maturity Model*: fuente original del modelo de madurez; describe capacidad organizativa y no puntúa por sí solo la calidad de una cacería — <http://detect-respond.blogspot.com/2015/10/a-simple-hunting-maturity-model.html>
- SURF, *TaHiTI Threat Hunting Methodology*: publicación original de la metodología para estructurar propósito, hipótesis, investigación y resultados — <https://www.surf.nl/en/knowledge-base/2018/threat-hunting-with-tahiti.html>
- Splunk, *PEAK Threat Hunting Framework*: material oficial para los enfoques hypothesis-driven, baseline y model-assisted — https://www.splunk.com/en_us/form/the-peak-threat-hunting-framework.html
- MITRE ATT&CK: fuente primaria de comportamientos que pueden originar hipótesis; elegir una técnica no demuestra que la hipótesis sea relevante localmente — <https://attack.mitre.org/>

- Bejtlich, R. *The Practice of Network Security Monitoring*. No Starch Press: bibliografía complementaria sobre investigación y monitoreo de red.



Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.



Clase anterior

[Clase 187 — Detección basada en MITRE ATT&CK](#)



Siguiente clase

[Clase 189 — Análisis de endpoints con EDR](#)